GRC103 **– LAB 3B**

Advanced Cybersecurity Risk Quantification

Student Name: Fatima Mustapha
Registration Number: C11/26/CGRCE/17593
Course: GRC103
Case Study: SecureBank Financial – SecureMobile Banking Platform

Submitted assignment report

1. Introduction and Scenario

This report analyses the cybersecurity risks identified in the SecureMobile banking application assessment for SecureBank Financial. It estimates financial exposure, compares three proposed controls, and provides a practical risk-treatment plan for management.

2. Method and Assumptions

Important assumption: the brief provides exploit probabilities of 15%, 25% and 40%, but does not provide a separate annual rate of occurrence (ARO) or a time period for those probabilities. For this lab calculation, each probability is treated as the estimated annual rate of occurrence (0.15, 0.25 and 0.40 events per year). The result is therefore an illustrative annual estimate, not a measured loss forecast.

Single Loss Expectancy (SLE) = financial loss from one incident. Annualized Loss Expectancy (ALE) = SLE × Annual Rate of Occurrence (ARO).

3. Phase 1 – Risk Exposure Calculations

Risk 1: API Authentication Bypass

SLE = maximum single incident loss = $5,000,000. ARO = 15% = 0.15. ALE = $5,000,000 × 0.15 = **$750,000 per year**.

Risk 2: Database Injection Vulnerability

SLE = 500,000 customer records × $250 per record = **$125,000,000**. ARO = 25% = 0.25. ALE = $125,000,000 × 0.25 = **$31,250,000 per year**.

Risk 3: Session Hijacking

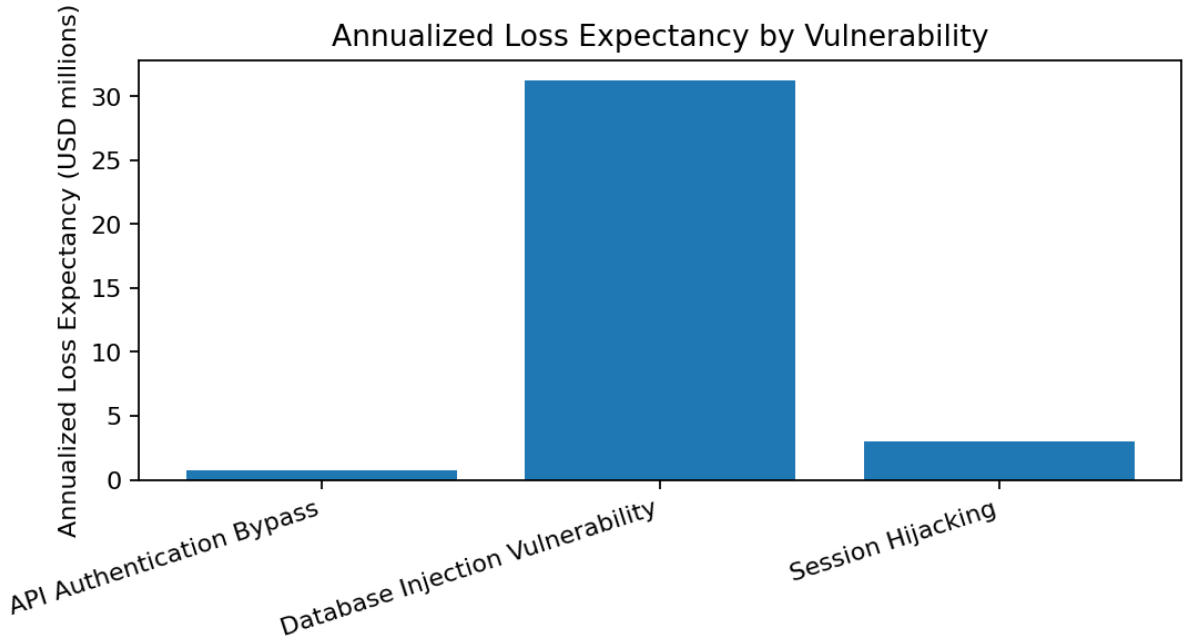
SLE = 5,000 accounts × $1,500 average loss per account = **$7,500,000**. ARO = 40% = 0.40. ALE = $7,500,000 × 0.40 = **$3,000,000 per year**.

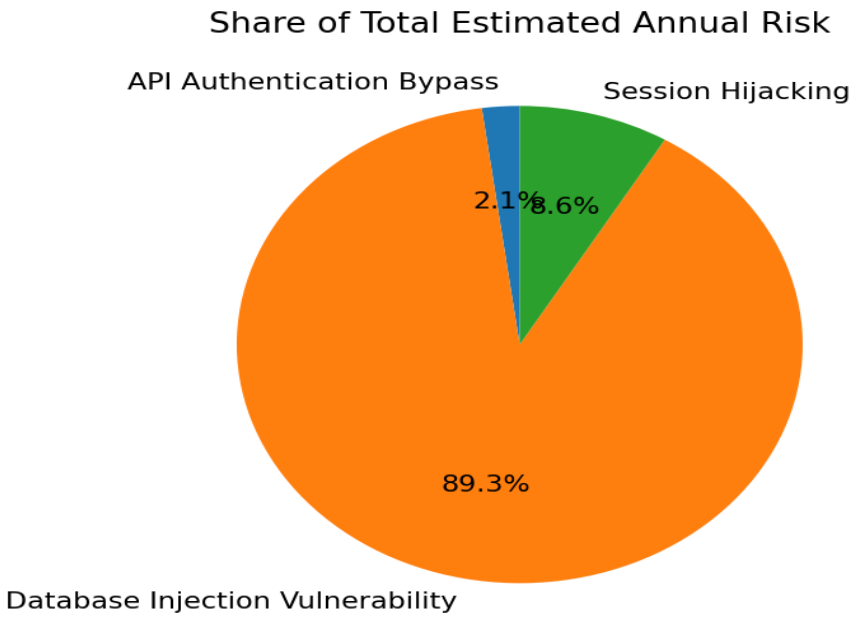
Vulnerability	SLE	ARO (assumed annual)	ALE	Priority
API Authentication Bypass	$5,000,000	0.1%	$750,000	High
Database Injection Vulnerability	$125,000,000	0.2%	$31,250,000	Critical
Session Hijacking	$7,500,000	0.4%	$3,000,000	High

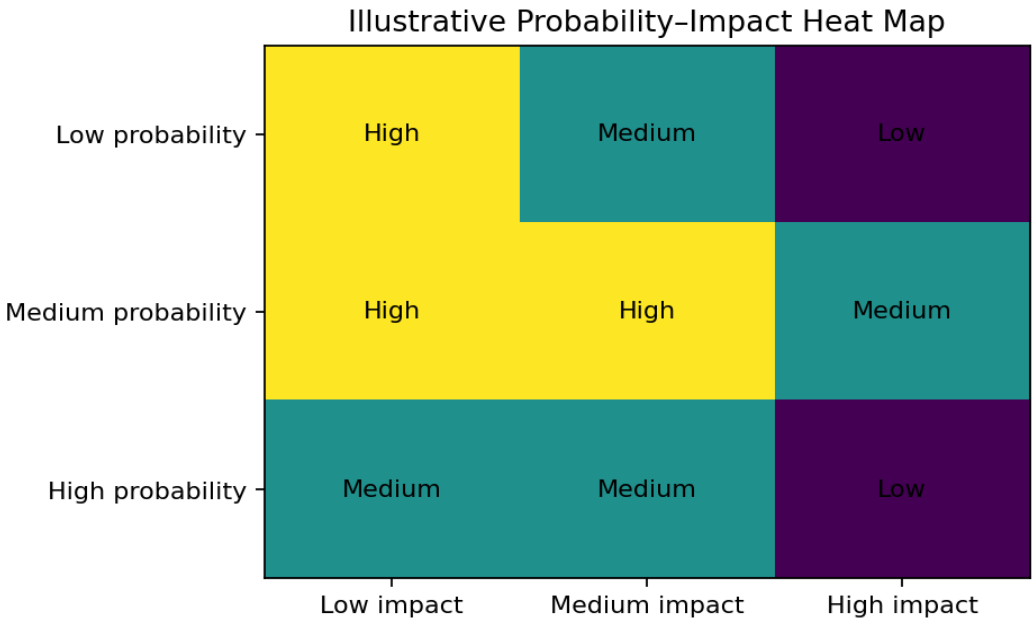
Prioritisation: database injection is the highest financial risk because its ALE is $31.25 million. Session hijacking is next at $3 million, followed by API authentication bypass at $750,000. The API issue still needs urgent attention because detection is estimated at 48 hours and the incident could involve unauthorised fund transfers.

4. Risk Visualisations

The charts below compare estimated annual losses and show the share of total quantified exposure. The heat map is a qualitative illustration because the brief does not specify a formal probability/impact scoring scale; the financial ALE ranking should be used alongside it.






Illustrative Probability–Impact Heat Map
Low probability
Medium probability
High probability
High
Medium
Low
High
High
Medium
Medium
Medium
Low
Low impact
Medium impact
High impact

5. Phase 2 – Control Evaluation

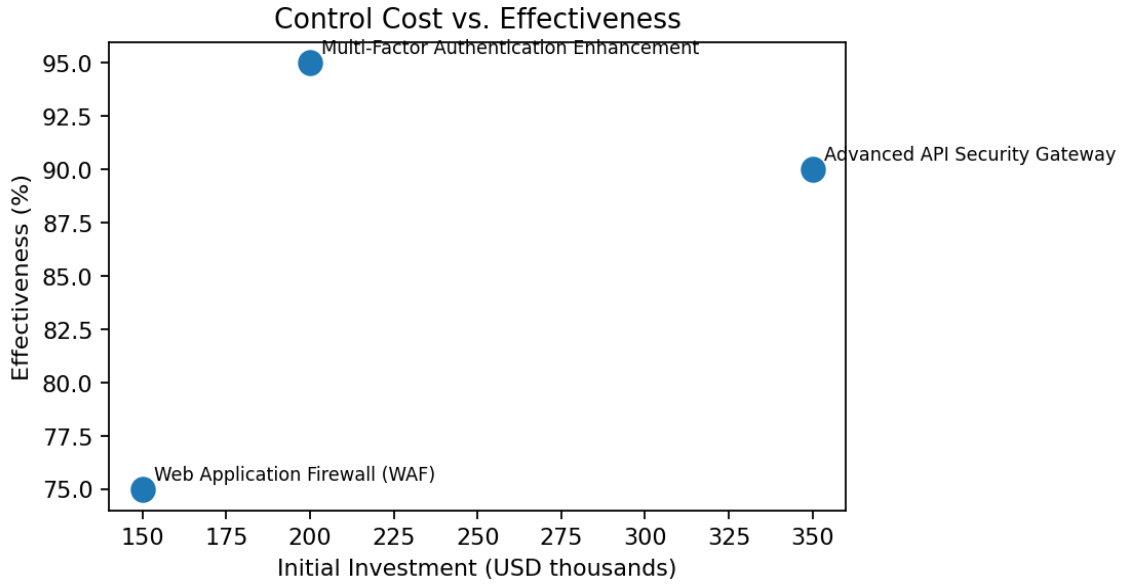
To compare controls consistently, each control is matched to the vulnerability it is designed to reduce. Risk reduction is calculated as the relevant ALE multiplied by the stated effectiveness. Annual net benefit is risk reduction less annual maintenance. Year 1 ROI is calculated as (annual risk reduction – annual maintenance – initial investment) ÷ initial investment × 100. Payback is initial investment divided by annual net benefit. These are simplified estimates and assume the stated effectiveness applies to the full matched risk.

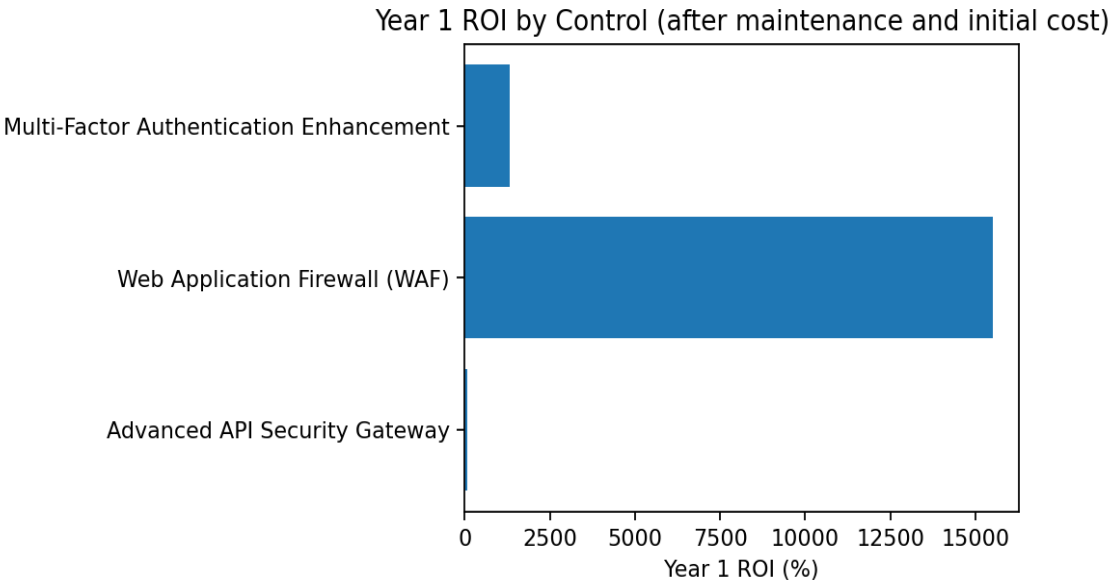
Control	Initial cost	Annual maintenance	Effectiveness	Annual risk reduction	Year 1 ROI	Payback
Advanced API Security Gateway	$350,000	$50,000	90.0%	$675,000	78.6%	0.56 years
Web Application Firewall (WAF)	$150,000	$25,000	75.0%	$23,437,500	15508.3%	0.01 years
Multi-Factor Authentication Enhancement	$200,000	$30,000	95.0%	$2,850,000	1310.0%	0.07 years

Example calculation – API Security Gateway: annual risk reduction = $750,000 × 90% = $675,000. Annual net benefit after maintenance = $675,000 – $50,000 = $625,000. Year 1 ROI = ($675,000 – $50,000 – $350,000) ÷ $350,000 × 100 = 78.6%. Payback = $350,000 ÷ $625,000 = 0.56 years (about 6.7 months).

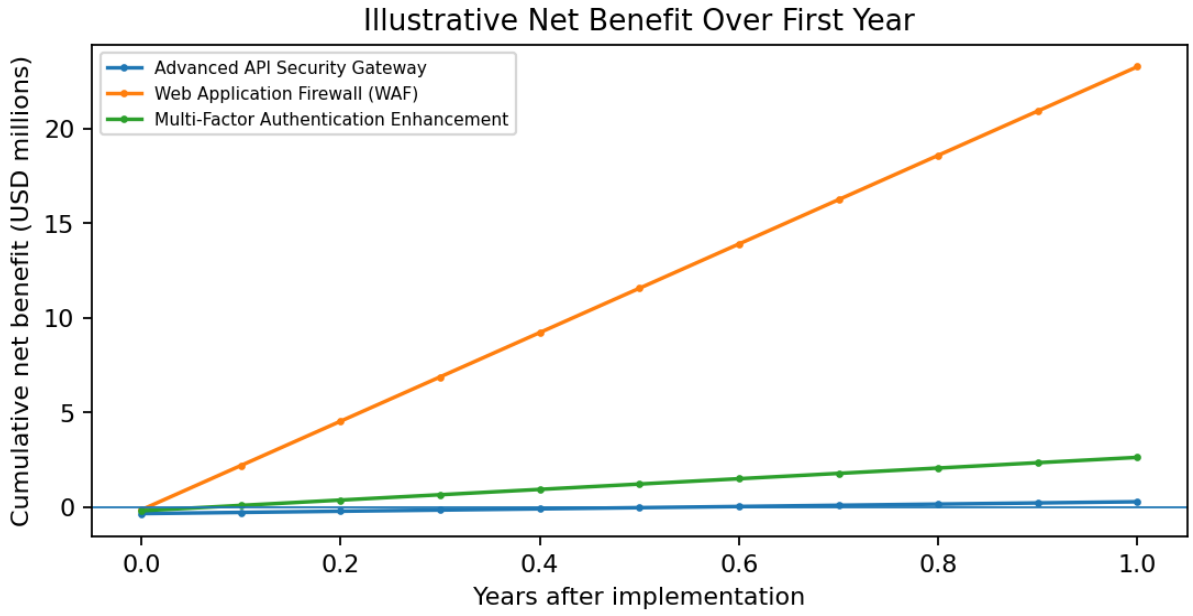
Example calculation – WAF: annual risk reduction = $31,250,000 × 75% = $23,437,500. Annual net benefit = $23,437,500 – $25,000 = $23,412,500. Year 1 ROI = ($23,437,500 – $25,000 – $150,000) ÷ $150,000 × 100 = 15,508.3%. Payback = $150,000 ÷ $23,412,500 = 0.0064 years (about 2.3 days).

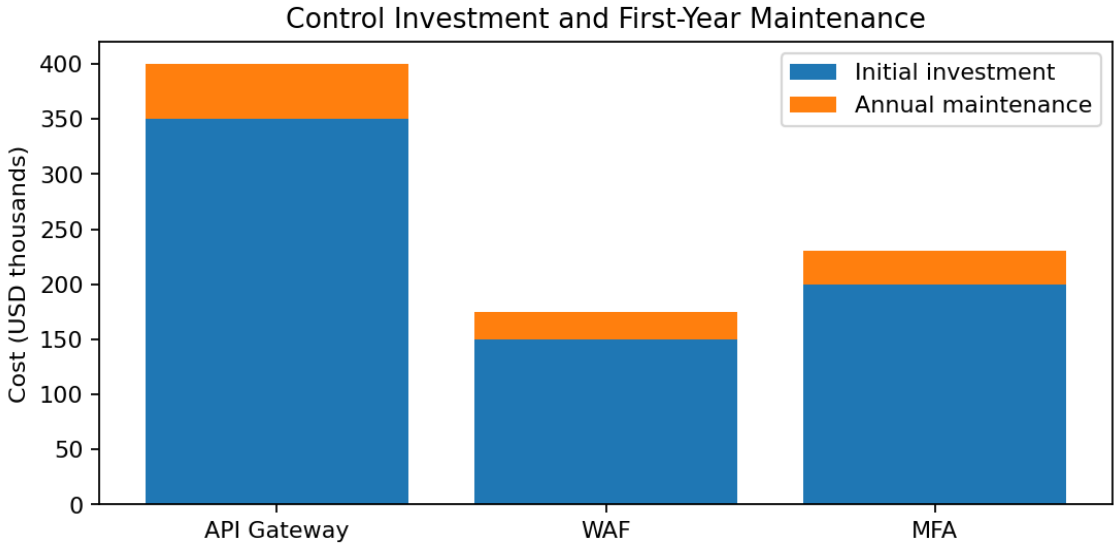
Example calculation – MFA: annual risk reduction = $3,000,000 × 95% = $2,850,000. Annual net benefit = $2,850,000 – $30,000 = $2,820,000. Year 1 ROI = ($2,850,000 – $30,000 – $200,000) ÷ $200,000 × 100 = 1,310%. Payback = $200,000 ÷ $2,820,000 = 0.071 years (about 26 days).

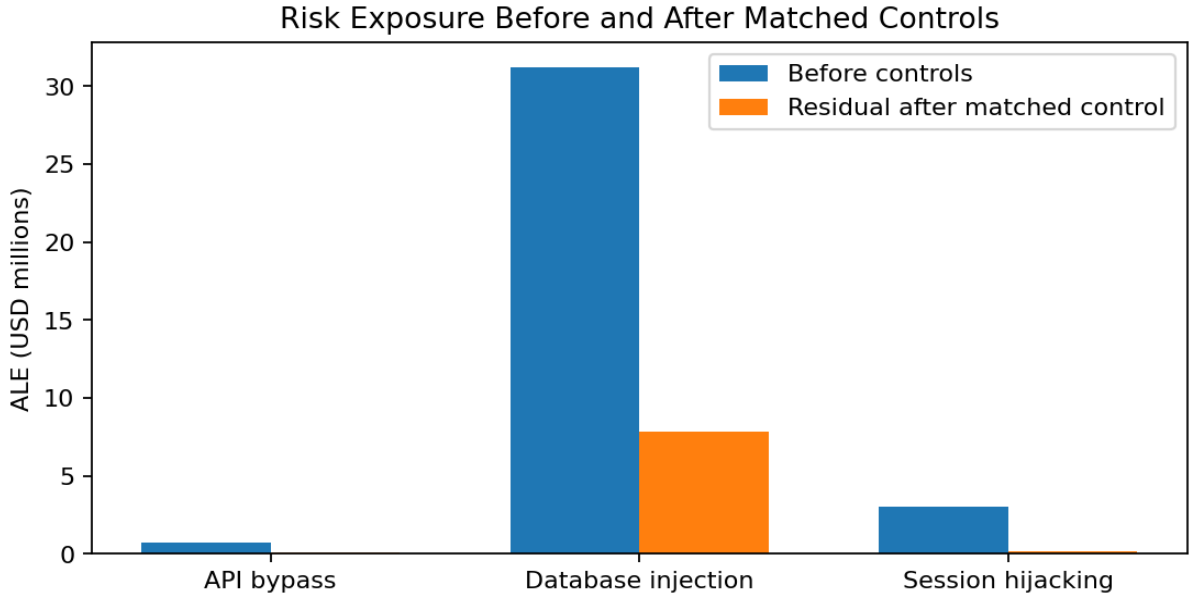



Year 1 ROI by Control (after maintenance and initial cost)
Multi-Factor Authentication Enhancement
Web Application Firewall (WAF)
Advanced API Security Gateway
0
2500
5000
7500
10000
12500
15000
Year 1 ROI (%)

6. Control Selection and Risk Reduction Over Time







Residual ALE after the matched control: API bypass = $750,000 × 10% = $75,000; database injection = $31,250,000 × 25% = $7,812,500; session hijacking = $3,000,000 × 5% = $150,000. Combined baseline ALE is $35,000,000. If all three matched controls perform as estimated and their effects can be treated independently, combined residual ALE is $8,037,500, a reduction of $26,962,500 (77.0%). Actual combined results may differ because controls can overlap and effectiveness is an estimate.

7. Executive Dashboard

Overall assessment: the three findings represent a combined estimated ALE of **$35,000,000 per year**, using the assumptions stated in this report. Database injection is the dominant exposure and should be treated first.

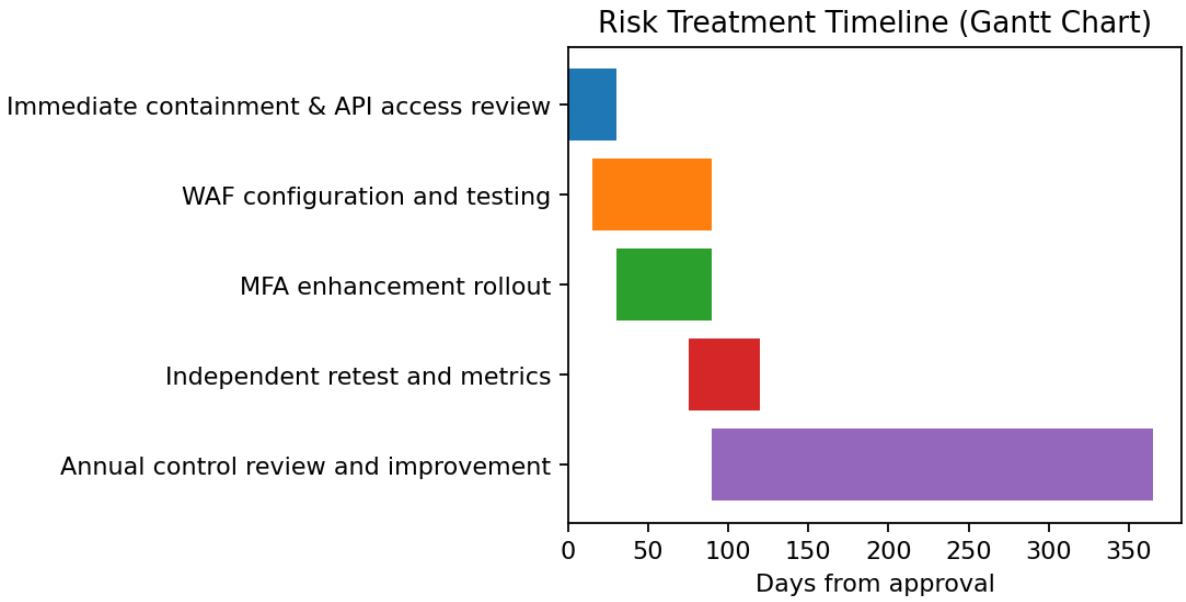
Top risk	Estimated SLE	ARO	ALE	Recommended action
Database injection	$125,000,000	25%	$31,250,000	Deploy/configure WAF; remediate injection at source; retest
Session hijacking	$7,500,000	40%	$3,000,000	Enhance MFA and review session controls
API authentication bypass	$5,000,000	15%	$750,000	Implement API gateway and fix authentication bypass

Recommended control investment

Control	Initial investment	Annual maintenance	First-year total
Advanced API Security Gateway	$350,000	$50,000	$400,000
Web Application Firewall (WAF)	$150,000	$25,000	$175,000
Multi-Factor Authentication Enhancement	$200,000	$30,000	$230,000

Combined initial investment = $700,000. Annual maintenance = $105,000. Total first-year cost = $805,000. Estimated annual risk reduction before maintenance = $26,962,500. Estimated first-year net benefit after maintenance and initial costs = $26,157,500. Portfolio-level year-one ROI = ($26,962,500 – $105,000 – $700,000) ÷ $700,000 × 100 = 3,736.8%. This is a simplified financial estimate and depends heavily on the assumption that the supplied exploit probabilities represent annual occurrence rates.

8. Risk Treatment Timeline



9. Risk Treatment Plan

Timeframe	Actions	Evidence of completion
Immediate (first 30 days)	Assign owners; validate findings; review API authentication and access logs; apply safe, approved fixes; log, assess, document and inci	Named owners, approved tickets, log reviews, database remediation and
Short term (by 90 days)	Deploy and tune WAF; remediate database injection at source; roll out enhanced MFA; test results, MFA and session controls, retest findings	Change records, test results, MFA and session report, closed findings, retest.
Long term (within 1 year)	Monitor control effectiveness; conduct recurring vulnerability scans and penetration tests; review risks, update risk register, report new	Quarterly risk dashboard, test results, updated risk register, report new

10. Bonus – Combined Risk-Control Matrix

Risk	Current ALE	Matched control	Effectiveness	Risk reduction	Residual ALE	Initial cost
API bypass	$750,000	API Security Gateway	90%	$675,000	$75,000	$350,000
Database injection	$31,250,000	WAF	75%	$23,437,500	$7,812,500	$150,000
Session hijacking	$3,000,000	MFA enhancement	95%	$2,850,000	$150,000	$200,000

Budget recommendation: if funding is constrained, prioritise the WAF and remediation of the database injection finding because it addresses the largest quantified exposure. MFA has a strong estimated reduction relative to its cost and should follow promptly. The API gateway should also be implemented because it materially reduces the risk of unauthorised transfers. This is not a reason to delay basic remediation of any critical vulnerability.

11. Conclusion

The assessment indicates that database injection creates the largest estimated annual financial exposure, followed by session hijacking and API authentication bypass. Based on the simplified cost-benefit calculations, all three proposed controls show positive first-year net benefit under the stated assumptions. Management should approve remediation, assign accountable owners, validate effectiveness through retesting, and update the figures when reliable incident-frequency and loss data become available.

Calculation note: all dollar values are in USD. Percentages and costs are based on the supplied lab brief. The report uses illustrative assumptions where the brief does not provide a required input.